Nombre: Cintia Kimberly Altamirano Cundapi
Fecha: 06 de Septiembre de 2026

HACKER WOMEN COUNCIL — ETHICAL HACKING

# Actividad 01. Análisis y planificación del pentest

A partir del escenario de Aurora Market, desarrolla los siguientes puntos

## 1 OBJETIVO DEL PENTEST

Define 3 objetivos concretos que tendría la evaluación de seguridad de Aurora Market

1. Identificar vulnerabilidades y riesgos que existen en la aplicación web de Aurora Market
2. Evaluar el impacto y nivel de riesgo de las vulnerabilidades identificadas, determinando como podrían afectar a la empresa
3. Proponer medidas de mitigación para reducir los riesgos y recomendaciones de seguridad para fortalecer la seguridad.

## 2 ALCANCE

Identifica claramente que se evaluará y que quedará fuera del alcance

**SI SE EVALUARÁ** Sistemas o elementos incluidos en el alcance

Solo la aplicación web autorizada : Aurora Market. Incluye funcionalidades de la aplicación relacionadas con la autenticación, consulta de productos y pedidos, carrito y compras; Las áreas de administración de productos, usuarios y pedidos , siempre que estén incluidas en la autorización.

**FUERA DEL ALCANCE** Elementos que no serán evaluados

Redes sociales, correos, equipos, proveedores, ni otros sistemas que no formen parte del alcance acordado

Nombre: Cintia Kimberly Altamirano Cundapi
Fecha: 06 de Septiembre de 2026

HACKER WOMEN COUNCIL — ETHICAL HACKING

## 3 AUTORIZACIÓN Y CONDICIONES

Explica que permisos y condiciones deben estar definidos antes de comenzar las pruebas

### PERMISOS REQUERIDOS

- Contar con una autorización formal y previa de Aurora Market al equipo de ethical hacking sobre la evaluación a la aplicación web de Aurora Market. Y acuerdos de confidencialidad y presupuesto.
- Definir claramente los sistemas, funcionalidades y objetivos que están autorizados para ser evaluados.

### CONDICIONES ACORDADAS

- No realizar acciones que interrumpan la plataforma o afecten la información real.
- Pruebas en horarios de menor actividad para minimizar impactos.
- Solo la aplicación web autorizada, excluyendo ataques a redes sociales, equipos, correos, proveedores, ni otros sistemas fuera del alcance.

## 4 TIPO DE PENTEST

Determina si el escenario corresponde a un Black-box, Gray-box o White-box. Investiga brevemente el concepto y justifica tu elección.

**Tipo de pentest elegido:** BLACK-BOX




**Justificación de la elección:**

No se proporciona información suficiente para considerarlo Gray-box, ya que no se mencionan credenciales, documentación técnica, código fuente ni información parcial de la infraestructura entregada al equipo. Tampoco corresponde a White-box, debido a que no se establece que el equipo tenga conocimiento completo de la arquitectura y código de la aplicación.

HACKER WOMEN COUNCIL — ETHICAL HACKING

# 5 PLANIFICACIÓN

Establece que deberia hacer el equipo antes de empezar la parte técnica. Completa los elementos clave.

## OBJETIVOS

- Identificar vulnerabilidades y riesgos de seguridad presentes en la aplicación web.
- Evaluar el impacto que podrían tener las vulnerabilidades identificadas sobre la empresa.
- Proponer medidas de mitigación para reducir los riesgos y fortalecer la seguridad.

## ALCANCE

- Evaluar únicamente la aplicación web autorizada de Aurora Market.
- Evaluar las funcionalidades que forman parte de dicha aplicación, como registro, inicio de sesión, productos, carrito, compras, pedidos y área administrativa, siempre dentro de la autorización.

**Fuera del alcance:** redes sociales, equipos, correos electrónicos, proveedores y cualquier otro sistema que no forme parte del alcance acordado.

## PERMISOS Y CONDICIONES

- Contar con autorización formal de Aurora Market antes de comenzar.
- Realizar las pruebas únicamente sobre la aplicación autorizada.
- No interrumpir deliberadamente el funcionamiento de la plataforma.
- No afectar información real de los clientes.
- Realizar las pruebas durante horarios de menor actividad.

## METODOLOGIA A UTILIZAR

- OWASP (Open Web Application Security Project) como metodología de referencia para realizar las pruebas de seguridad de la aplicación web.

## RECOPILACIÓN DE INFORMACIÓN PREVIA

- Información disponible sobre la aplicación web.
- Dominios y URLs autorizados.
- Funcionalidades incluidas en el alcance.
- Tipos de usuarios y roles existentes.
- Horarios de menor actividad.
- Procedimientos para reportar un incidente durante las pruebas.

## RECURSOS NECESARIOS

- Personal calificado (analistas de seguridad o pentester con experiencia)
- Computadoras.
- OWASP ZAP para análisis y pruebas de seguridad de la aplicación web.
- Herramientas de reconocimiento y análisis de tráfico, según las pruebas autorizadas.
- Herramientas para documentar evidencias y resultados.
- Tiempo requerido

## PROGRAMACIÓN DEL PENTEST

- Aproximadamente 3 a 6 semanas para realizar la evaluación, dependiendo del tamaño y complejidad de la aplicación.

Nombre: Cintia Kimberly Altamirano Cundapi
Fecha: 06 de Septiembre de 2026

Nombre: Cintia Kimberly Altamirano Cundapi
Fecha: 06 de Septiembre de 2026

HACKER WOMEN COUNCIL — ETHICAL HACKING

6

# FASES DEL PENTEST

Explica como aplicarias cada fase al caso de Aurora Market. ¿Qué buscarías hacer en cada etapa.

## 1. RECONOCIMIENTO

Se recopilará información sobre la aplicación web autorizada de Aurora Market sin intentar explotar vulnerabilidades. Se identificarán dominios y subdominios, direcciones IP, tecnologías utilizadas, servicios expuestos y funcionalidades de la aplicación. También se buscará conocer los diferentes tipos de usuarios y roles existentes. Se respetará en todo momento el alcance establecido.

## 2. ANÁLISIS DE VULNERABILIDADES

A partir de la información obtenida, se buscarán posibles vulnerabilidades y configuraciones inseguras en la aplicación. Se evaluarán aspectos como autenticación, autorización, control de acceso, componentes desactualizados y exposición de información. Se prestará especial atención al incidente reportado, donde un usuario aparentemente pudo visualizar información de otra cuenta. Los hallazgos obtenidos mediante herramientas automáticas serán verificados manualmente para evitar falsos positivos.

## 3. EXPLOTACIÓN

Se comprobará de manera controlada si las vulnerabilidades identificadas son realmente explotables y se evaluará su impacto. Por ejemplo, si se detecta una posible falla de autorización, se comprobará si un usuario puede acceder a información de otra cuenta. Las pruebas se realizarán sin modificar o eliminar información real ni interrumpir deliberadamente la plataforma.

## 4. POST-EXPLOTACIÓN

Si se obtiene acceso mediante una vulnerabilidad, se evaluará hasta dónde podría llegar un atacante dentro del alcance autorizado. Se comprobará si es posible obtener mayores privilegios, acceder a funciones administrativas o consultar información que debería estar restringida. También se analizará el impacto que tendría una mala configuración o el uso de credenciales predeterminadas que permita obtener privilegios administrativos.
Las pruebas se realizarán de forma controlada, sin eliminar registros, modificar información real ni realizar acciones que puedan afectar la operación de la empresa.

## 5. INFORME

Se documentarán los resultados de la evaluación, indicando para cada vulnerabilidad dónde fue encontrada, qué evidencia se obtuvo, su nivel de gravedad, impacto y si fue posible explotarla. También se incluirán recomendaciones específicas para corregir las vulnerabilidades y fortalecer la seguridad de la aplicación. El informe permitirá a Aurora Market conocer no solamente qué vulnerabilidades existen, sino también cómo priorizar y corregir los riesgos identificados.

Nombre: Cintia Kimberly Altamirano Cundapi
Fecha: 06 de Septiembre de 2026

HACKER WOMEN COUNCIL — ETHICAL HACKING

# 7 INVESTIGACIÓN

Consulta al menos una de las metodologías que vimos en clase y explica porque podría ser útil para este proyecto

## METODOLOGÍA ELEGIDA

OWASP (Open Worldwide Application Security Project), específicamente OWASP Web Security Testing Guide (WSTG).

## POR QUÉ SERÍA ÚTIL PARA ESTE PROYECTO

OWASP (Open Worldwide Application Security Project) es una comunidad global dedicada a mejorar la seguridad de las aplicaciones mediante educación, documentación, herramientas y buenas prácticas. Para el Pentest de Aurora Market se utilizará como referencia, específicamente la OWASP Web Security Testing Guide (WSTG), que guía la realización de pruebas de seguridad en aplicaciones web. Es adecuada porque Aurora Market maneja usuarios, productos, compras y pedidos, permitiendo evaluar aspectos relevantes como autenticación, autorización y control de acceso, especialmente por el incidente reportado. Entre sus recursos también se encuentran OWASP Top 10 y las Cheat Sheet Series, que ayudan a identificar riesgos y conocer medidas para prevenirlos y corregirlos.

Como apoyo durante las diferentes fases del Pentest, se podrían utilizar:

- OWASP ZAP: análisis de la aplicación web y detección de posibles vulnerabilidades.
- Burp Suite: análisis e interceptación de peticiones HTTP/HTTPS para realizar pruebas de autenticación, autorización y control de acceso.
- Nmap: reconocimiento de servicios y puertos expuestos, únicamente sobre activos autorizados.
- WhatWeb: identificación de tecnologías utilizadas por la aplicación.

Los resultados deben verificarse manualmente para confirmar que las vulnerabilidades sean reales.

En Aurora Market, OWASP permitiría evaluar especialmente el posible problema reportado por el cliente: que un usuario pueda acceder a información de otra cuenta.

OWASP Zed Attack Proxy

NMAP

BURPSUITE

WhatWeb